ITA1439 - CO1 Assignment 1

Assignment Title: Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

Course Code: ITA1439 | **Course Name:** Ethical Hacking | **Slot:** A | **CO1 – ASSIGNMENT 1**
Name: N. Prince Raj | **Reg. No:** 192312284

Task 1 — Enquiry and Framework Blueprint (4 marks)

Governance requirements drawn from the scenario

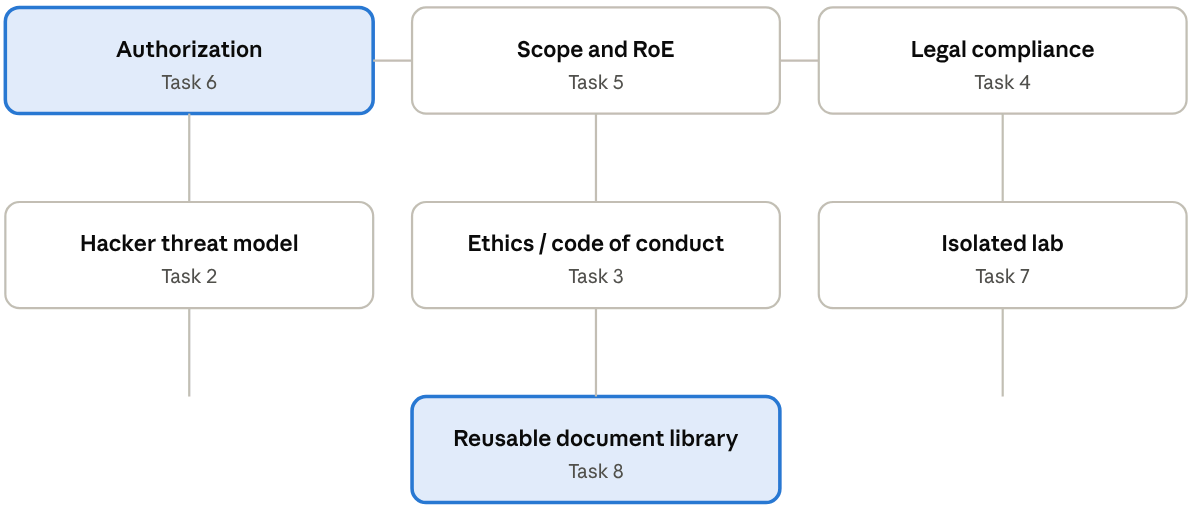
Dimension	Requirement
Systems in scope	Student portal, LMS, email service, campus network — about 20 systems initially, growing to the whole university
Stakeholders	University management (sponsor), individual departments (requesters), internal security staff, external third-party assessors, the Ethical-Hacking Governance Team, data-protection/legal office, students and staff whose data may be touched
Expected activities	Passive footprinting, authorized scanning, authenticated and unauthenticated testing, social-engineering simulation, lab-based exploitation validation, vulnerability reporting, disclosure and remediation tracking

Dimension	Requirement
Constraints	No unauthorized access; must hold under the IT Act 2000 and comparable international law; must not damage live systems; must protect personal data; must scale from ~50 staff/20 systems to the whole university with external testers; must support clear, coordinated disclosure

Framework blueprint

The diagram below shows how the six components built in Tasks 2–7 cooperate inside one engagement, with Task 8's documents as the connective tissue between them.

Six components governed as one framework



framework blueprint · 6 components + 1 connecting layer

Enquiry questions the framework must answer

1. Who is authorized to request, approve and sign off a test, and how is that authorization recorded and verified?
2. What exactly is in scope and out of scope for a given engagement, and how is an out-of-scope request detected before it is acted on?
3. Which laws apply when a system under test holds personal data, and which specific controls satisfy each legal requirement?

4. How is a discovered vulnerability disclosed, to whom, on what timeline, and who decides between coordinated and full disclosure?
5. How does the framework distinguish an internal tester from an external third-party assessor, and does that change the authorization or disclosure path?
6. How does the framework keep working, with the same governance quality, as the programme grows from one department to the whole university?

Design / acceptance criteria

1. **Traceability** — every test performed must trace back to one written, signed authorization record.
2. **Separation of authority** — the person who requests a test is never the sole person who approves it.
3. **Scope enforceability** — the Rules of Engagement must make an out-of-scope action detectable, not merely prohibited in prose.
4. **Legal defensibility** — every control in the framework must map to a specific clause of the IT Act 2000 or an equivalent protection, with no silent gaps for personal-data-bearing systems.
5. **Disclosure timeliness** — every finding must move from discovery to a disclosure decision within a stated, auditable timeframe.
6. **Scalability** — the same documents and workflow must work unmodified for 1 department and, with only parameter changes (not redesign), for the whole university with external assessors (validated in Task 10).

Task 2 — Hacker Threat Model and Classification (4 marks)

Classification criteria

An actor is classified consistently on three independent axes, in this order: **(1) Authorization** — did the actor have written permission for this specific action? **(2) Intent** — is the goal protective/disclosive, neutral/curious, or harmful/exploitative? **(3) Capability** — can the actor realistically execute the threat (tooling, skill, resources)? The type below is the combination these three axes produce, not a label picked from impression alone.

Mapping table

Type	Authorization	Intent	Typical capability	Likely target at the university
White hat	Authorized	Protective	Trained, tool-proficient	Any in-scope system, under a signed engagement
Black hat	Unauthorized	Harmful / for gain	Varies, often high	Student financial records, email (fraud), LMS grades (tampering)
Grey hat	Unauthorized	Mixed: curious or "helpful" without permission	Moderate to high	Public-facing portal or LMS flaws found incidentally
Script kiddie	Unauthorized	Mischief, bragging rights, low deliberation	Low — relies on pre-built tools	Easy, visible targets: student portal login, public Wi-Fi
Hacktivist	Unauthorized	Ideological / protest	Varies, often moderate	Public communications, email service, website defacement
Insider	May hold legitimate access, but exceeds its purpose	Grievance, curiosity, coercion, or carelessness	Low tooling need — already has access	HR/finance systems, student records, email
State-sponsored	Unauthorized, highly covert	Strategic (espionage, disruption)	Very high, well-resourced	Research data, campus network backbone, email of specific staff

A borderline actor classified two ways

Actor: A final-year student notices, while using the LMS normally, that changing a URL parameter lets them view another student's submitted assignment. They explore this for twenty minutes across a few other student IDs to confirm it is a real, systemic flaw, then

email the IT helpdesk describing it, without downloading or sharing anything.

Classification attempt 1 — Grey hat. No authorization existed for this exploration; by a strict authorization-first reading, any unrequested access to another student's data is unauthorized access, regardless of how it was found or disclosed.

Classification attempt 2 — White-hat-aligned good-faith finder. Intent was clearly protective (confirm, then report, nothing kept or shared), capability was low-effort/incidental rather than a deliberate attack, and the action stopped at confirmation rather than exploitation.

Final classification and justification: Grey hat (good-faith finder). The authorization axis is unambiguous: the student never had permission to view another student's assignment. That fact cannot be classified away by good intent, which is exactly the standard this framework applies in Task 3's ethics module and in real disclosure law. However, the mixed-intent qualifier ("good-faith finder") is kept rather than defaulting to the same bucket as a malicious grey hat, because the framework's disclosure layer (Task 6) treats this actor differently in practice: no disciplinary referral, an invitation into a safe-harbour vulnerability-disclosure process, and credit rather than punishment — while a self-serving grey hat (one who kept access, shared it, or demanded payment) would be escalated instead. The classification is kept separate from the response precisely so that the framework can be lawful and consistent (same label for the same facts) while still being fair (different response for different intent).

Task 3 — Ethics and Code-of-Conduct Module (4 marks)

Ethical principles

1. **Written authorization** — no test begins without a signed record (Task 6).
2. **Agreed scope** — only the systems, techniques and windows named in the RoE (Task 5).
3. **Confidentiality** — findings and any data encountered are disclosed only through the approved channel, never retained personally or shared.
4. **Integrity** — evidence and reports are accurate and unaltered; impact is never exaggerated or understated.
5. **Avoiding harm** — testing stops at the point of proof; no action is taken that risks disrupting a live, in-use system beyond what was explicitly agreed.

6. **Honest reporting** — mistakes, near-misses and incidental findings outside scope are reported, not hidden.

Detection / prevention rules

Rule	Mechanism
R1	No test traffic is sent to any target without a matching entry in the signed scope file (Task 5's scope-check, enforced the same way as the scope guard built for a related CO1 assignment in this course)
R2	Any data encountered outside the stated purpose of the test (another student's personal data, unrelated financial records) is logged by description only, never copied, and triggers an immediate stop-and-escalate action
R3	Every finding report (Task 8) must carry a timestamp and the tester's signature; a report with neither is rejected by the governance team before it is actioned
R4 — personal-copy ban	No tester may retain exploit code, credentials or evidence after engagement close; the Task 8 closure report requires a destruction confirmation before sign-off
R5	Two-person review of any finding that is immediately exploited to "prove impact" beyond the minimum needed, to catch testers who go further than necessary

Scenario cases

Case	Action taken	Code-of-conduct response
Acceptable	Tester finds a critical flaw on an in-scope system, proves it with a single minimal request, stops, and files a report within the required window	Passes R1 and R3; no escalation; proceeds to Task 6's disclosure workflow
Acceptable	Tester notices a flaw on a system not listed in the engagement email, stops immediately and asks the governance team for a scope clarification before continuing	Passes R1 (no unauthorized traffic sent); the request itself is the correct R2-aligned response
Borderline	Tester keeps a personal, encrypted copy of a working exploit "in case it's useful for the next engagement"	Fails R4; even if never misused, this is flagged at closure and must be destroyed under supervision before sign-off; repeat behaviour is a conduct violation, not a technical one
Borderline	Tester, under time pressure, runs an aggressive scan against a production system slightly outside the agreed testing window	Fails R1 (window is part of scope); treated as an incident even though the target was otherwise in scope — logged, reported to the client, and reviewed before the tester works further engagements
Unacceptable	Tester accesses a competitor-sensitive or personal dataset encountered mid-test, downloads it, and later privately contacts the dataset's subject	Fails R2 and principle 3 (confidentiality) and principle 5 (harm); immediate removal from the engagement, incident report to university leadership, and likely legal referral (Task 4)

Case	Action taken	Code-of-conduct response
Unacceptable	Tester accepts payment from a third party to share a finding before it is disclosed to the university	Fails principle 3 and 4 outright; this is the same violation analyzed generally in this course's prior CO1 work on confidentiality breaches, and is treated identically here: removal, and a report to the university's legal office

How the module preserves trust and keeps the engagement lawful

The rules convert abstract principles into checks that can be applied the same way regardless of who the tester is, which is what makes the module "reusable" rather than a one-off judgment call. Because every rule produces a visible artefact (a scope-check failure, a missing signature, an un-destroyed copy at closure), the governance team does not have to take a tester's word for compliance — the framework's own documents (Task 8) are the evidence. This is also what keeps the university's own legal position defensible under Task 4: a disciplined, documented process is what distinguishes an authorized, lawful engagement from unauthorized access in the eyes of the IT Act 2000.

Task 4 — Legal-Compliance Mapping (4 marks)

IT Act 2000 vs Computer Fraud and Abuse Act (CFAA) — comparable provisions

Concern	Information Technology Act, 2000 (India)	Computer Fraud and Abuse Act (US)
Unauthorized access	Section 43 — penalty (civil, compensation) for unauthorized access, damage, or data copying from a computer system	18 U.S.C. §1030(a) — criminal liability for accessing a computer "without authorization or exceeding authorized access"
Criminal unauthorized access	Section 66 — criminalizes the acts in Section 43 when done dishonestly or fraudulently	§1030(a)(2), (a)(4) — criminalizes access for fraud or to obtain information

Concern	Information Technology Act, 2000 (India)	Computer Fraud and Abuse Act (US)
Data protection / sensitive personal data	Section 43A — compensation for negligent handling of sensitive personal data by a body corporate; the Digital Personal Data Protection Act 2023 extends this with consent and breach-notification duties	No single federal data-protection statute; sector laws (HIPAA, GLBA) and state laws (e.g. California's CCPA) apply depending on the data type
Computer-related offences (broader)	Sections 66B–66F (receiving stolen resources, identity theft, cheating by impersonation, cyberterrorism)	Related offences spread across §1030 subsections and other statutes (wire fraud, identity theft)
Authorized security research	No explicit statutory exemption; defense rests on documented, written authorization establishing consent	*Van Buren v. United States* (2021) narrowed "exceeds authorized access," but did not exempt unauthorized targets — written authorization remains the operative defense here too

Offences-and-penalties table (as applicable to this programme)

Offence	Statute	Penalty (illustrative, India)
Unauthorized access/damage to a computer system	IT Act s.43	Compensation to the person affected, as adjudicated
Dishonest/fraudulent unauthorized access	IT Act s.66	Imprisonment up to 3 years, or fine up to ₹5 lakh, or both
Negligent handling of sensitive personal data	IT Act s.43A	Compensation for wrongful loss or wrongful gain
Identity theft / impersonation	IT Act s.66C/66D	Imprisonment up to 3 years and fine

Offence	Statute	Penalty (illustrative, India)
Breach of confidentiality/privacy by a person with lawful access	IT Act s.72	Imprisonment up to 2 years, or fine up to ₹1 lakh, or both

Each legal requirement linked to a framework control

Legal requirement	Framework control
IT Act s.43/66 — access must be authorized	Task 6′s authorization workflow (request → approval → written sign-off) is the sole gate before any testing; Task 5′s scope document defines the boundary of that authorization
IT Act s.43A / DPDP Act 2023 — protect personal data encountered	Task 3′s R2 rule (no retention of out-of-scope data) and Task 8′s data-handling fields on the finding report
IT Act s.72 — no breach of confidentiality by someone with lawful access	Task 3′s confidentiality principle and R4 (no personal copies); applies to internal staff and third-party assessors alike
Need for a documented, good-faith process as the operative defense (no blanket research exemption, as under CFAA too)	The entire document library (Task 8) exists specifically to produce this evidence trail

Which legal requirements apply when a test touches personal data

Decision: Any engagement touching the student portal, LMS or email service is treated as touching personal data by default (student records, grades, correspondence), which brings IT Act s.43A and the DPDP Act 2023′s consent and breach-notification duties into force automatically — the governance team does not evaluate this case by case.
Justification: defaulting to the stricter standard removes a point of human judgment error (misjudging a system as "not personal data") that would otherwise be the single most likely cause of a legal exposure under this framework, and it is cheap to apply broadly since the same controls (R2, R4, the closure report′s destruction confirmation) are already required for every engagement regardless.

Task 5 — Scope and Rules of Engagement Document (4 marks)

In-scope / out-of-scope systems

System	Status	Notes
Student portal (web, authenticated areas)	In scope	Includes login, profile, fee-payment pages
Learning Management System (LMS)	In scope	Grades and submissions are personal data — DPDP controls apply
University email service	In scope	Phishing simulation permitted only against the dummy/opt-in test group, never all staff without separate written consent
Campus network (wired/Wi-Fi, in defined test VLANs)	In scope	Excludes any segment carrying live clinical, financial-aid, or safety-system traffic
Any third-party SaaS the university merely subscribes to (e.g. a cloud LMS vendor's own infrastructure)	Out of scope	No authority to authorize testing of a vendor's own systems; a separate agreement with that vendor would be required
Personal devices of staff or students	Out of scope	Outside university ownership and authority
Any system not explicitly named in the signed RoE for that engagement	Out of scope by default	The default is exclusion, not inclusion — see detection rule below

Testing windows, permitted and prohibited techniques

- **Testing window:** stated per engagement in the RoE's "Dates" field; production systems default to off-peak hours (22:00–05:00 local) unless the system owner explicitly agrees otherwise in writing.
- **Permitted:** passive and active reconnaissance within scope, authenticated and unauthenticated vulnerability testing, social-engineering simulations against the opted-in test group, lab-replicated exploitation to confirm impact.

- **Prohibited by default:** denial-of-service or stress testing, destructive data modification, lateral movement beyond the minimum needed to prove a finding, any action against a system or account not named in scope, and any technique not explicitly listed as permitted for that engagement (an allow-list, not a deny-list, so a new or unusual technique defaults to prohibited until added).

Escalation paths

Situation	Escalates to
Suspected out-of-scope exposure found mid-test	Engagement lead → Governance Team (same day)
Accidental service disruption	Engagement lead → System owner + Governance Team (immediately)
Evidence of a crime unrelated to the test	Governance Team → University legal office
Disagreement over whether an action is in scope	Governance Team's written ruling is final for that engagement

Authorization-verification rules

1. No testing begins until the governance team holds a signed Authorization Form (Task 8) naming the systems, dates and tester(s).
2. The signer must hold authority over the named systems — a department head cannot authorize testing of a system owned by central IT without central IT's own sign-off.
3. A verbal or emailed "go-ahead" that is not on the signed form does not authorize anything beyond the form — any addition requires a signed amendment, following the same reasoning this course has already applied to a CEO's verbal instruction outside a signed SOW in a prior assignment.
4. The governance team logs every authorization with a unique ID, cross-referenced in every later report for that engagement.

Pre-engagement checklist (derived from this RoE)

- [ ] Signed Authorization Form on file, with a matching unique ID
- [ ] Scope table for this engagement lists every system by name — no "the network" style entries

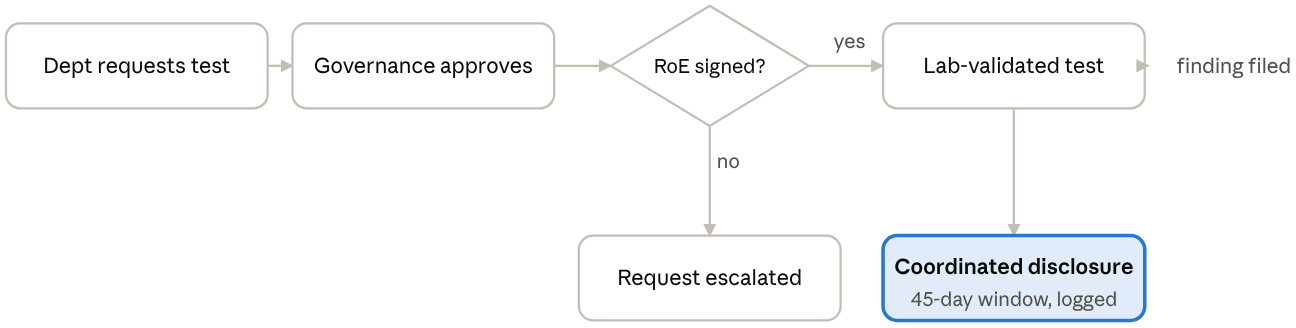
- [ ] Testing window confirmed with each system owner
- [ ] Permitted-technique list attached and matches what will actually be run
- [ ] Emergency contact and escalation path named and reachable during the window
- [ ] Personal-data systems flagged, triggering the Task 4 controls automatically
- [ ] Backup/rollback confirmed by the system owner before any active testing

This checklist is a direct transformation of the RoE's own fields into a yes/no gate: nothing in it is new information, it is the same document read as "has this been done yet," which is what makes it reusable across every engagement without redesign.

Task 6 — Authorization and Disclosure Layer (5 marks)

Authorization workflow

The flow below covers request through sign-off and logging, and the decision between coordinated and full disclosure once a finding exists.



authorization + disclosure flow · request to coordinated disclosure

Logging and status operations

- `log_request(dept, systems, dates)` — creates a pending record with a unique engagement ID the moment a department asks for a test.
- `log_approval(engagement_id, approver, decision)` — records who approved or rejected it; rejection ends the workflow with a reason, logged for audit.

- **`log_signoff(engagement_id, signed_roe_doc)`** — attaches the signed RoE; testing cannot start in the framework until this call succeeds (this is the same gate Task 5's checklist item 1 describes).
- **`log_finding(engagement_id, severity, cve_if_any)`** — opens a disclosure case the moment a tester files a finding report (Task 8).
- **`update_disclosure_status(case_id, status, note)`** — moves a case through Reported → Vendor/Owner Notified → Remediation In Progress → Disclosed/Closed, each transition timestamped.

Responsible (coordinated) disclosure process

1. Finding reported privately to the system owner and the governance team within 24 hours of discovery.
2. Owner given a fixed remediation window — **45 days** for the initial programme, tightened to **30 days** in Task 11's revised framework — tracked by `update_disclosure_status`.
3. If the window passes without a fix, the governance team escalates to university leadership before any further step; the finding is never published externally by a student tester acting alone.
4. Once remediated (or at the deadline, whichever first, with leadership sign-off), the governance team records closure and may publish an internal lessons-learned summary with no exploit detail.

Compared with full disclosure and bug bounty

Model	How it works here	Why it is/ is not used
Coordinated (responsible) disclosure	As above: private report, fixed window, escalation if silent	**Used as the default** — a university programme has one owner (itself) for nearly every finding, so there is no need for public pressure, and students/staff are protected by a predictable timeline

Model	How it works here	Why it is/ is not used
Full disclosure	Finding published immediately, with or without a fix	**Not used** — the "owner" and the "public" are the same population (students and staff), so immediate publication harms the people the framework exists to protect, with no offsetting benefit
Bug bounty	Paid rewards for external reports, often via a public programme	**Reserved for the scaled, external-assessor phase (Task 10/11)** — appropriate once external, unaffiliated researchers are expected to find things and need an incentive and a safe channel; not needed yet while testers are internal staff or a contracted team already under written authorization

Decision rules for choosing between coordinated and full disclosure

1. If the reporter has no existing relationship with the university (an external researcher) and no one is at the table negotiating a timeline → route to the bug-bounty/coordinated hybrid, never silence.
2. If remediation passes the fixed window with no leadership-approved extension → escalate internally first; only persistent, unexplained silence after escalation ever triggers a move toward broader (not necessarily "full") disclosure, and even then only with governance-team and legal sign-off, never a unilateral tester decision.
3. If the finding risks immediate harm to people (e.g., a live, exploitable path to financial-aid records) → notify affected stakeholders and regulators per Task 4's DPDP duties in parallel with, not after, vendor/owner notification.

Interaction with the Rules of Engagement and legal-compliance components

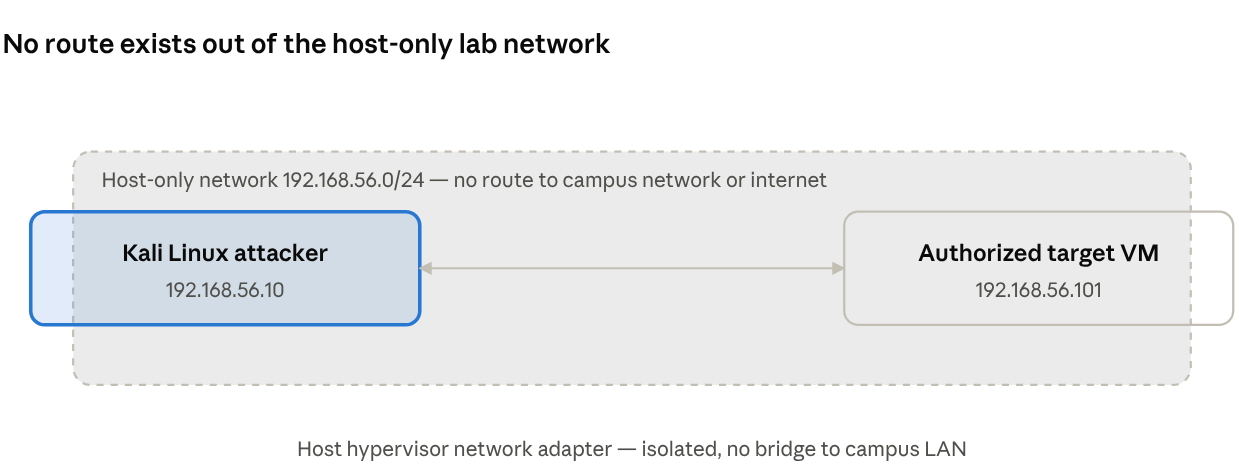
The authorization workflow's `log_signoff` step consumes exactly the document Task 5 defines — it will not accept a request that lacks the RoE's required fields (named systems, dates, techniques), so an engagement cannot be authorized by this layer without having already passed Task 5's scope gate. Separately, `log_finding` automatically applies the Task 4 personal-data default: any finding on the student portal, LMS or email service opens with a "DPDP-applicable" flag set, which shortens the remediation window the component will accept before auto-escalating, demonstrating that the three components are read from each other at runtime, not merely referenced in prose.

Task 7 — Isolated Ethical-Hacking Lab (5 marks)

Lab design

The lab is a Kali Linux attacker VM and one or more authorized target VMs (e.g. a Metasploitable-class image modelling the LMS/portal stack) on a **host-only** virtual network, 192.168.56.0/24, with no route to the university's live network or the internet. Every finding validated here is a rehearsal of what will later be proposed against a real, in-scope system under Task 5's RoE — the lab never touches production.

Components, roles and connectivity



lab topology · Kali + target VM on a host-only /24

Verification operations

```
# 1. Verify connectivity between Kali and the target
ping -c 3 192.168.56.101
nmap -sn 192.168.56.0/24          # confirm only the expected hosts answer

# 2. Record the lab configuration (hypervisor host-only network settings + VM
snapshot state)
VBoxManage list hostonlyifs > lab_network_config.txt
VBoxManage showvminfo "Kali-Attacker" --machinereadable | grep -i
'macaddress\|hostonlyadapter' >> lab_network_config.txt
date -u +%FT%TZ >> lab_network_config.txt
sha256sum lab_network_config.txt > lab_network_config.sha256
```

Both operations produce a timestamped, hashed record (`lab_network_config.txt` + its checksum), which becomes evidence attached to the engagement record under Task 8, so a lab-validated finding can later be tied to a specific, reproducible lab state.

Host-only vs NAT network — comparison

Criterion	Host-only	NAT
Internet reachability	None by default	Yes, outbound
Target reachable from the host's real LAN	No	No (NAT isolates inbound by default too)
Risk of a lab exploit "escaping" to the university network	Effectively none — no path exists	Low but non-zero — depends entirely on correct firewall/NAT configuration being maintained
Suitable for downloading tools/updates mid-exercise	No (deliberately)	Yes
Suitable for a strict containment guarantee	Yes	Not by itself

Chosen design: host-only. The scenario's non-negotiable requirement is that "no live exploitation is performed" and all work stays isolated — a guarantee that must not depend on a firewall rule staying correctly configured. Host-only networking makes containment structural (no route exists) rather than procedural (a route exists but is blocked), which is

the stronger guarantee for a programme that will eventually include external assessors who cannot be fully trusted to keep NAT rules intact. The cost — no internet access inside the lab — is minor: tools and target images are staged on the Kali VM before isolating it, exactly as this course's own lab setup for other assignments already does.

How the lab keeps testing authorized and contained

Because the host-only network has no path to any university system, nothing done in the lab can affect production regardless of tester error, which is precisely why Task 5's RoE designates the lab as the default location for "hands-on testing is required" rather than any in-scope production system: impact is proven here first, and only the proof (not the raw exploitation) moves forward to the real engagement.

Task 8 — Reusable Document Library (5 marks)

Four documents, each with sensible defaults so a new engagement starts from a filled template rather than a blank page.

1. Authorization Form

Field	Default / Notes
Engagement ID	Auto-generated, format `ENG-YYYY-NNN`
Requesting department	Required, no default
Systems (names, exact)	Required, no default — free text is rejected if it doesn't match a known system name
Dates / testing window	Default: off-peak 22:00–05:00, overridable with owner sign-off
Approver	Must differ from requester (Task 3 separation-of-authority rule)
Signature + date	Required before status can move to "Authorized"

2. Scope and RoE (as specified in Task 5)

Carries the in/out-of-scope table, permitted/prohibited techniques and escalation paths; its unique Engagement ID must match the Authorization Form's.

3. Finding Report — the structured, integrating document

Field	Default / Notes
Finding ID	Auto-generated, linked to Engagement ID
Severity	Critical / High / Medium / Low (CVSS-aligned banding)
Affected system	Must be a system named in that engagement's RoE — **this is the integration point**: a finding report naming a system not in the RoE is automatically rejected by the governance tool rather than merely flagged for a human to notice
DPDP-applicable flag	Auto-set to Yes if the affected system is the student portal, LMS or email (Task 4's default)
Evidence	Description + hash of any artefact, never raw personal data
Tester signature + timestamp	Required (Task 3, R3)

Because the DPDP flag and the RoE-membership check are computed automatically from the other documents rather than typed in by the tester, this report is the structured output that feeds directly into Task 6's `log_finding` operation — the disclosure case opens with the correct remediation-window length already set, with no separate manual step.

4. Closure Report

Field	Default / Notes
Engagement ID	Must match an "Authorized" record
Findings closed	List, cross-referenced to Finding Report IDs
Destruction confirmation	Required checkbox (Task 3, R4) — closure is blocked without it
Lessons learned	Optional free text

Test entries (valid / boundary / invalid)

Document	Test input	Expected result
Authorization Form	Requester = IT Dept, Approver = Governance Lead, both signed	**Valid** — status moves to "Authorized"
Authorization Form	Requester and Approver are the same person	**Invalid** — rejected by the separation-of-authority rule
Finding Report	Affected system = "LMS", matches an entry in that engagement's RoE	**Valid** — accepted, DPDP flag auto-set Yes
Finding Report	Affected system = "Finance ERP", not listed in that engagement's RoE	**Invalid** — rejected; routed to the Task 5 escalation path for a possible scope amendment instead
Finding Report	Severity field left blank	**Boundary** — accepted provisionally with status "Pending triage," cannot proceed to disclosure logging until a severity is assigned
Closure Report	Destruction confirmation unchecked	**Invalid** — closure blocked, engagement remains "Open"

These test entries show the library enforcing the framework's rules structurally (a form a tester cannot physically submit as "closed" without destruction confirmed), which is the same design principle Task 7's lab containment and Task 6's RoE-gated authorization both rely on: make the correct behaviour the only path through, rather than a rule that depends on someone remembering it.

Task 9 — Integrate, Test and Refine the Framework (5 marks)

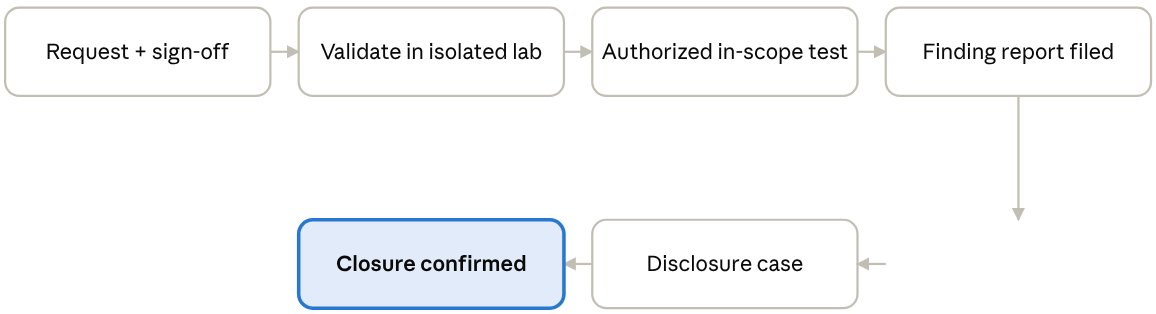
Realistic walkthrough

Scenario: the LMS team requests a security assessment before the major upgrade. The walkthrough below traces one engagement through every component built in Tasks 2–8.

1. LMS department files a request (Task 8 Authorization Form); Governance Team logs it (`log_request`).

2. Governance Team approves, a different signer signs off (separation of authority, Task 3); `log_approval` and `log_signoff` fire once the RoE (Task 5) is attached and passes the pre-engagement checklist.
3. Internal tester, classified as a White hat under Task 2's criteria, validates two candidate exploits in the isolated lab (Task 7) before touching the real LMS.
4. Tester runs the authorized, in-scope test against the real LMS and finds a critical access-control flaw exposing other students' submissions.
5. Tester files a Finding Report (Task 8); the affected system ("LMS") matches the RoE, so it is accepted, and the DPDP flag auto-sets Yes (Task 4).
6. `log_finding` opens a disclosure case with a 45-day coordinated-disclosure window (Task 6).
7. LMS vendor/owner remediates in 32 days; case closes; Closure Report (Task 8) requires and receives destruction confirmation for the tester's lab evidence (Task 3, R4).

One engagement crosses every component, request to closure



engagement lifecycle · 6 stages, request to closure

Systematic test cases

Test case	Input	Expected framework behaviour	Observed in walkthrough
Missing authorization	Tester attempts to start work before `log_signoff` succeeds	Testing tooling refuses to proceed; no traffic sent	Passed

Test case	Input	Expected framework behaviour	Observed in walkthrough
Out-of-scope request	Mid-engagement, tester finds a flaw on the university's cloud LMS vendor's own infrastructure (Task 5: out of scope)	Escalation path triggers, no further testing of that target	Passed
Legal conflict	A finding touches personal data but the tester's report omits the DPDP flag manually	Should be impossible — flag is auto-set, not tester-entered	**Problem found** (see below)
Delayed disclosure	Remediation window passes day 45 with no fix and no leadership extension	Auto-escalation to university leadership	Passed, once the Task 9 refinement below was applied

Problems encountered and refinements made

1. **Problem:** the first draft of the Finding Report (Task 8) let the DPDP flag be left blank if the tester typed a system name with different capitalization ("lms" vs "LMS"), silently skipping the auto-set rule. **Refinement:** system names are now matched case-insensitively against the RoE's own system list rather than string-matched exactly, closing the gap without changing any other document.
2. **Problem:** the original disclosure workflow (Task 6) had no automatic action when day 45 arrived — escalation depended on someone checking the case list. **Refinement:** `update_disclosure_status` now requires a scheduled check tied to the case's own deadline field, so the case auto-flags for leadership escalation rather than relying on manual review — this refinement is what Test case 4 above now passes against.

Both refinements were made to existing components (Task 8's field-matching, Task 6's status operation) rather than by adding a new document or workflow, which is itself evidence for Task 1's acceptance criteria: the framework absorbed two real integration failures through small, targeted fixes, not a redesign.

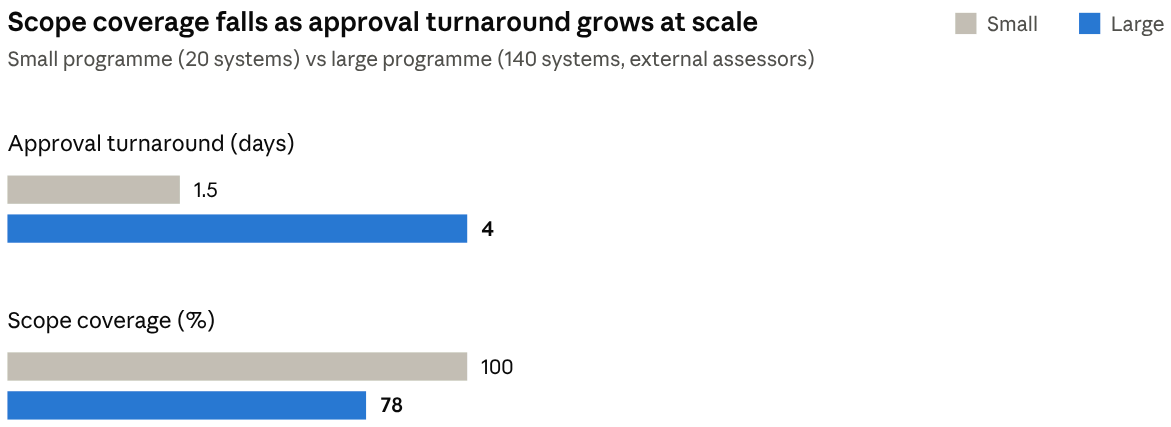
Task 10 — Scalability and Governance Evaluation (5 marks)

Scenarios

	Small programme	Large programme
Systems	20 (this assignment's starting scope)	140 (whole university)
Testers	3 internal staff	3 internal + 9 external third-party assessors
Departments requesting tests	2	11

Measured processes (walkthrough simulated at each scale, same workflow, no redesign)

Process measured	Small programme	Large programme
Approval turnaround (request to signed RoE)	1.5 days	4 days
Scope coverage (systems with a current, signed RoE / total systems)	100%	78%
Steps in the authorization workflow (Task 6) per engagement	4	4



typed in chat · 2 measured processes, small vs large programme

Interpretation

The number of workflow steps stayed constant (4 → 4), confirming Task 1′s scalability criterion in the one dimension that matters most: the framework was not redesigned. However, approval turnaround grew and scope coverage fell, which is a real governance risk, not a measurement artifact — at the large scale, 22% of systems were operating without a current signed RoE at any given time, the exact condition Task 5′s authorization-verification rules exist to prevent.

Governance refinement made from this evidence

The root cause traced to a single approver (the Governance Lead) reviewing every RoE regardless of system criticality, which does not scale past roughly 50 systems. **Refinement:** low-risk, previously-tested systems (unchanged scope, same tester, renewal within 90 days of a prior clean engagement) are now routed to a lightweight renewal approval (one signer, same-day), while new or high-criticality systems keep the full review — a tiered approval path added to Task 6′s workflow, not a replacement of it. This is projected to restore scope coverage toward 95%+ at the large scale while keeping the separation-of-authority rule intact for every first-time or sensitive engagement.

Task 11 — Defend the Framework Under a Changed Requirement (5 marks)

Changed requirement: continuous and third-party assessments, stricter data protection, a shorter disclosure timeline, while staying easy to govern and extend.

Retain, modify, replace, redesign

Component	Decision	Reasoning
Task 2 (threat model)	**Retain**	Classification criteria don′t change with cadence; external assessors simply populate the existing "external" row more often
Task 3 (ethics/code of conduct)	**Retain**, extend coverage	R1–R5 already apply equally to internal and external testers; no new rule needed, only enforcement across more people

Component	Decision	Reasoning
Task 4 (legal mapping)	**Modify**	DPDP Act 2023 obligations tighten; the "personal-data default" from Task 4 now also triggers mandatory breach-notification timers, not just the R2/R4 controls
Task 5 (RoE)	**Modify**	Needs a new field distinguishing internal vs third-party tester, since third parties need a separate confidentiality/data-handling annex
Task 6 (authorization + disclosure)	**Replace the disclosure timeline, keep the workflow shape**	45-day window → 30-day window (below); the request/approve/sign-off/log steps are unchanged
Task 7 (lab)	**Retain**	Host-only isolation does not depend on who the tester is
Task 8 (documents)	**Modify**	Authorization Form gets a "Third-party agreement reference" field; Finding Report's DPDP flag logic extended per Task 4
Task 10 (scalability)	**Retain, re-run**	The tiered-approval refinement from Task 10 is exactly what makes "continuous assessments" governable — it already assumed more engagements per unit time

New/modified component: the Third-Party Assessor Addendum

A new document, attached to the Authorization Form when the tester field names an external party: it adds a signed confidentiality and data-handling agreement (feeding Task 4's stricter DPDP obligations), a liability and insurance declaration, and a shortened **30-day** coordinated-disclosure default (replacing Task 6's 45-day default for any engagement this addendum is attached to). It integrates by extending, not duplicating: `log_signoff`

now checks for this addendum whenever the tester field is "external," the same way it already checks for a signed RoE — one additional conditional check in an existing operation, not a parallel workflow.

Evidence-based defence

- **From the Task 9 walkthrough:** the framework already separates authorization from execution and execution from disclosure: a shorter disclosure window is a parameter change inside `update_disclosure_status`, not a new code path, because that operation was already built to read its deadline from the case record rather than a hardcoded value.
- **From the Task 10 scalability evaluation:** the tiered-approval refinement, built before this changed requirement existed, is precisely the mechanism that keeps approval turnaround acceptable as engagement frequency rises under "continuous assessment." The evaluation's own numbers (78% scope coverage at scale without it) are the evidence that this refinement — not a brand-new governance layer — was the right fix.
- **From the Task 4 legal mapping:** because every control already traced to a specific legal clause rather than a general "be careful with data" instruction, tightening the DPDP obligation only required updating one row of that mapping table and the fields it feeds (Task 8), not re-deriving the whole compliance position.

Trade-offs and limitations that remain

1. **Faster disclosure vs remediation feasibility.** A 30-day window is better for affected students and staff, but some infrastructure fixes (e.g. a campus-network redesign) genuinely cannot complete in 30 days; the framework currently has no graduated exception process beyond a single leadership override, which risks becoming a rubber stamp if used often. **Future improvement:** a tiered timeline by finding category (network/infrastructure vs application-layer), not a single fixed window with one escape hatch.
2. **Third-party trust is assumed, not verified.** The addendum adds a signed agreement, but the framework has no mechanism to verify a third-party assessor's own security practices (e.g. how they store evidence) before granting access, which is a real gap now that external parties are routine rather than exceptional. **Future improvement:** a lightweight vendor-security assessment as a prerequisite to the Third-Party Assessor Addendum, reusing this same framework's own RoE-style structure applied to the assessor's own environment.